

CISCO SECURE WORKLOAD

SOC 2 Compliance Framework

Trust Services Criteria — Type II

Prepared for: [Customer Name]

Prepared by: Cisco Systems, Inc.

Date: [Month Year] | Version 1.0 | Cisco Confidential

Regulatory Standard: SOC 2 Type II (AICPA Trust Services Criteria)

Environment: Hybrid (On-Premises + Cloud)

Deployment Stage: Fresh Installation

How to read the Coverage column

Direct means Secure Workload produces the primary evidence artifact for that row — segmentation, policy, flow and process telemetry, inventory, vulnerability and reachability, or forensic reconstruction. Direct is still evidence, not an attestation.

Supporting means Secure Workload contributes an input that feeds or complements another control, tool, or process — detection input only, reconciled against an external register, or one log source among several.

Evidence Required means Secure Workload has no record for that row. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

Every report in this set now uses the same three coverage words — Direct, Supporting, and Evidence Required. Coverage describes what evidence Secure Workload produces; it never means the control is passed.

Executive Summary

SOC 2 Type II audits evaluate whether security controls operated effectively over a defined audit period (typically 6–12 months). Cisco Secure Workload (CSW) directly satisfies the Security Trust Services Criteria and contributes to Availability, Confidentiality, and Processing Integrity criteria through continuous workload visibility, micro-segmentation, vulnerability detection, and forensic telemetry.

Coverage Summary

Criteria Category	Ref	Control	Requirement	CSW Implementation	Coverage
Security (CC6)	CC6.1	Logical Access Controls	Restrict logical access to systems	Workload-level allowlist policies; default-deny inbound; process-level access logging	Direct
Security (CC6)	CC6.6	Network & Infrastructure	Network controls restrict unauthorized access	ADM maps all communication paths; micro-segmentation enforces least-privilege	Direct
Security (CC6)	CC6.7	Transmission Controls	Protect confidential data in transit	Detect/block HTTP, FTP, plain LDAP; enforce HTTPS/SFTP/LDAP S across all scopes	Direct
Security (CC7)	CC7.1	Vulnerability Detection	Identify and address vulnerabilities	Continuous CVE scanning with CVSS scoring on all in-scope workloads	Direct
Security (CC7)	CC7.2	System Monitoring	Monitor system components for anomalies	Real-time flow + process telemetry; anomaly detection; sensor health monitoring	Direct
Security (CC7)	CC7.3	Security Event Evaluation	Evaluate and respond to security	Forensic telemetry enables full incident	Direct

			events	reconstruction; alert export to SIEM	
Security (CC8)	CC8.1	Change Management	Control changes to infrastructure and systems	Policy workspace versioning; ADM baseline comparison detects drift	Direct
Security (CC9)	CC9.1	Risk Mitigation	Identify and mitigate risks	Vulnerability data + ADM attack surface feeds risk register; compensating controls	Direct
Availability (A1)	A1.1	Availability Monitoring	Monitor system availability	Sensor health monitoring; workload telemetry continuity; offline agent alerts	Direct
Confidentiality (C1)	C1.1	Confidential Info Protection	Protect confidential information	Confidential data scope isolation; encryption enforcement; access audit logging	Direct

Key CSW Capabilities for SOC 2

CC6 — Logical & Physical Access Controls

CSW enforces workload-level allowlist policies that satisfy CC6.1 and CC6.6. Every inbound connection to in-scope systems requires explicit policy approval. ADM generates a complete, auditable map of all communication paths, eliminating undocumented access routes that commonly fail SOC 2 audits.

CC7 — System Operations

Continuous CVE scanning with CVSS scoring satisfies CC7.1 vulnerability detection requirements. Full process and network telemetry with anomaly detection satisfies CC7.2 system monitoring. Forensic telemetry with flow search enables the security event evaluation required by CC7.3.

CC8 — Change Management

CSW policy workspace versioning provides an immutable audit trail of all security control changes. Quarterly ADM re-runs detect unauthorized changes to system communication patterns — serving as continuous configuration drift detection for CC8.1.

Evidence Collection Guide

The following evidence artifacts satisfy SOC 2 Type II auditor requirements:

Evidence Artifact	CSW Source	CC Control	Frequency
Access control policy export	Defend → Policy Workspaces	CC6.1	Per audit request
Policy violation log	Alerts → Triggered Events	CC6.1, CC6.6	Monthly export
Vulnerability scan report	Investigate → Vulnerability	CC7.1, CC9.1	Weekly
Network flow audit log	Investigate → Flow Search	CC6.7, CC7.2	Continuous
Anomaly alert log	Alerts → Dashboard	CC7.2, CC7.3	Monthly
ADM application map	Investigate → ADM	CC6.6, CC8.1	Quarterly
Sensor health report	Manage → Agents	CC7.2, A1.1	Monthly
Policy change audit trail	Policy workspace history	CC8.1	Per change

Deployment Recommendations

- Enable full flow telemetry retention from Day 1 — SOC 2 Type II requires evidence across the entire audit period (6–12 months minimum)
- Configure alert export to SIEM for centralized evidence collection and automated review
- Run ADM before enforcement — document the approved baseline before locking down communication paths
- Schedule quarterly ADM re-runs to detect configuration drift for CC8.1 change management evidence
- Set CVSS ≥ 7.0 alert threshold for immediate notification on high-severity vulnerabilities